

Assignment 3 - WAF Design Phase - Group 6

Members:

Timothy Loudon

Melvin Viado

Daniel Lindo

Table of Contents

Contents

Table of Contents.....	2
Security Policy Overview.....	3
Google Cloud Armor WAF and Network Design Diagram	5
Network Architecture Design and Traffic Flow Breakdown	6
1. Protection against	6
2. Important design implementations	6
-Traffic flow Throughout the Topology.....	6
-Monitoring Integration	7
-Multi-AZ (Availability Zone) design.....	7
-Testing Implementation	8
References	9

Security Policy Overview

Google Cloud Armor comes with many built-in security policies for organizations to use, operating at the application layer level of the OSI model by filtering inbound traffic going to the web server. These policies can be adjusted to suit the needs of the organization such as geo-restricting access based on country of origin, filtering IP addresses that don't come from a specified range, restricting access to network resources based on time of day, and interfacing with Application and Network Load Balancers to apply these policies and rules.

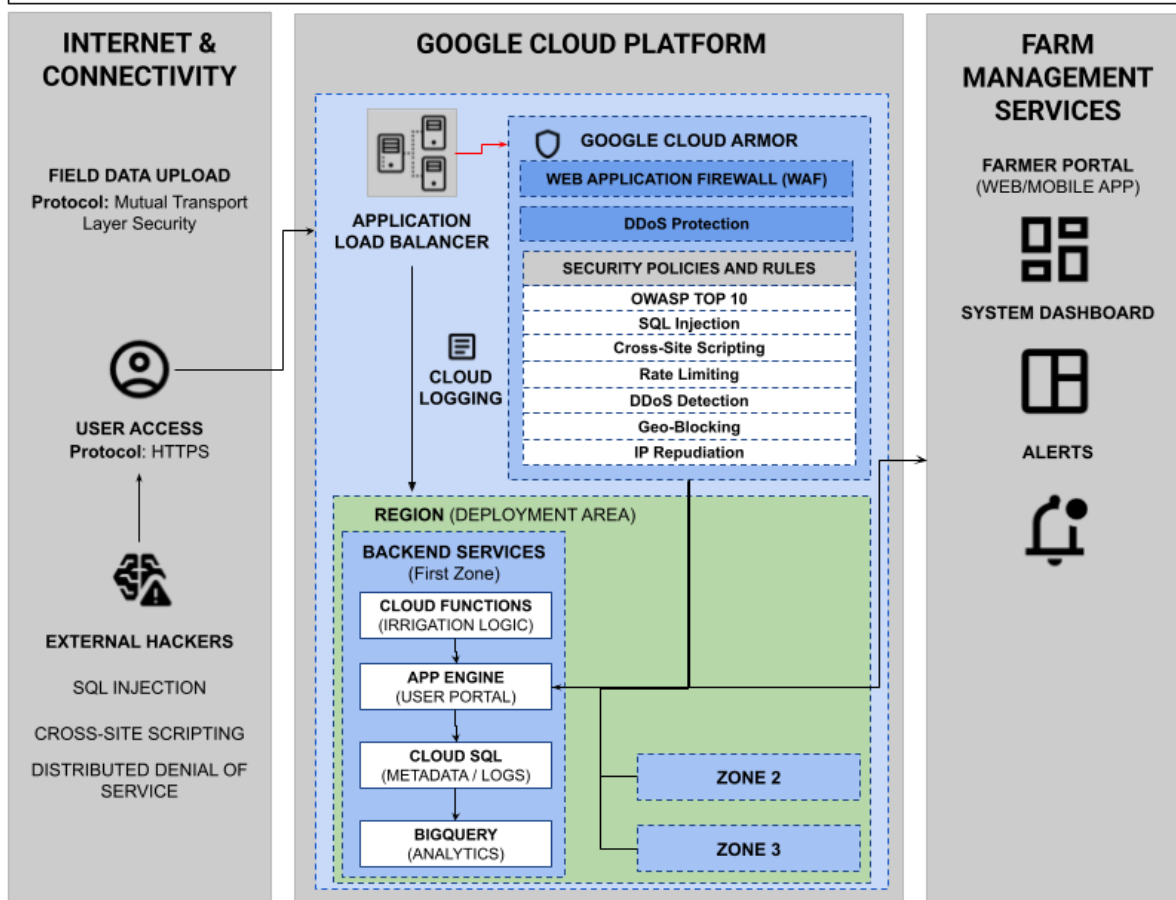
By default, Google Cloud Armor has protection against the top 10 application security risks as defined by OWASP including SQL Injections and Cross-Site Scripting in the form of preconfigured rules that work in tandem with security policies. All of the rules are sourced from the latest OWASP Core Rule Set (currently version 3.3) and there are other optional rules to protect servers from exploits such as Log4j and JSON-based SQL injection. Every rule in Cloud Armor also contains what is known as a paranoia level ranging from levels one to four that dictates how aggressively a rule is implemented. For example, a level one paranoia event will only trigger if certain actions occur, leading to it triggering rarely, but with a high degree of confidence that the issue is real and not a false positive. Similarly a level four paranoia will look at events more broadly and has a higher chance of triggering a false positive more often. These paranoia levels can also be adjusted manually, depending on how worried an organization is about certain exploits or events happening in the network.

Rules in Google Cloud Armor can also be customized based on needs and preferences using an easy to learn syntax that will be familiar to programmers. These custom rules in addition to the preconfigured ones help to build the backbone for Cloud Armor's security policies and have built-in support for allowing traffic from designated IP address ranges, user region codes, if the browser has a specific cookie and more. All of these considerations and customizability that defends an organization's web server from various attack vectors including the OWASP top 10 application security risks.

For a simpler organization, OWASP recommends keeping paranoia level on the lower end, while businesses like financial institutions or nuclear power plants are more likely going to use levels three and four. Rule strategies for these simpler companies should focus on ensuring that users have successfully completed Captchas to mitigate brute force attacks, ensure that tokens being used are valid, and restricting incoming and outgoing data from IP addresses from blocked regions/subnets.

Google Cloud Armor WAF and Network Design Diagram

INFT1204 Assignment 3 Design Phase - Design of Network Infrastructure and Network Flow - Group 6 (Melvin Viado, Tim Loudon, Daniel Lindo)



Network Architecture Design and Traffic Flow Breakdown

Our network architecture design will be built with protection in mind, primarily against OWASP top 10 web application security risks, along with SQL injection and Cross Site Scripting. Other notable features will also include:

1. Protection against

- Owasp top 10 web application threats

- SQL Injection

- Cross-Site Scripting

Each of these three primary protections will be utilized in the default template directly from Google Cloud Armor WAF, as it is by design built to handle such traffic and monitoring needs. Even though there are standard policies we can make use of to address these issues, we will also ensure to make use of policies that address the other requirements of the cloud infrastructure topology. We will also make use of customized policies to enforce practical configurations, such as Geo-Blocking, IP Repudiation and Rate limiting. Configurations will also factor in DDoS attacks and port scanning from bad actors.

2. Important design implementations

- Traffic flow Throughout the Topology

Firstly, we will showcase in our diagram multiple users first reaching the load balancer, in which we will make use of policies that limit the rates of users, specifically 100 requests per 5 minutes per IP Address. From the load balancer traffic we then reach the Google Cloud Armor WAF which will be tasked with ensuring that users are legitimate, traffic is filtered accordingly by geographical area, and that traffic that is being sent by users

is truly trustworthy and not an attack/payload from a bad actor, blocking that from succeeding.

The design will then showcase the various availability zones that will receive the traffic from the clients to access the application, and whether or not any attacks from bad actors reached the web based application running on the servers in the AZs. To keep track of the logs being generated from the GCA WAF, the logs will be exported to Amazon Cloudwatch for further analysis.

-Monitoring Integration

When it comes to monitoring integration, we are going to have the logs that are generated from the Google Cloud Armor WAF and export them to Amazon Cloudwatch. Although GCA WAF has the ability to generate logs and observe them, it is not nearly as effective as the organized design of Amazon Cloudwatch. Amazon Cloudwatch will provide the dashboard that will monitor the incoming attack trends, traffic volume and logs.

-Multi-AZ (Availability Zone) design

To ensure that users can access the web application safely and efficiently, we will make use of multiple availability zones for the web application on the servers. We also want to do this to ensure that multiple users from multiple geographical locations can have access to the web application without the server becoming overwhelmed from the number of users. Although the web applications being used are intentionally vulnerable, we will treat this implementation as if both attackers and legitimate clients are trying to access the application beyond the Google Cloud Armor Web Application Firewall while in action.

-Testing Implementation

Our pressure test of our topology will involve multiple attack types. We will primarily start with simulations of attacks that would be present within the OWASP Top 10, and then navigate to attacks that involve SQL Injection and Cross-Site Scripting (XSS). Following this, we will also simulate DDoS attack patterns, along with port scans, to test the effectiveness of the Google Cloud Armor WAF.

Considerations will also be made to see if the logs are properly generated during the testing phase of the network, along with tests to check geo-blocking and rate limiting in relation to one hundred requests every five minutes, for each IP Address from potential clients and bad actors. We will also test other policies to see if they're functioning up to standard, such as allow and block configurations for connections from users.

References

- Folini, C. (n.d.). *An Introduction to ModSecurity and the OWASP Core Rule Set*. OWASP. https://owasp.org/www-chapter-germany/stammtische/hamburg/assets/slides/2021-04-14_OWASP_ModSec-CRS-Intro.pdf
- Google. (n.d.-a). *Cloud armor preconfigured WAF rules overview | google cloud armor | google cloud documentation*. Google. <https://docs.cloud.google.com/armor/docs/waf-rules>
- Google. (n.d.-b). *Product overview | google cloud armor | google cloud documentation*. Google. <https://docs.cloud.google.com/armor/docs/cloud-armor-overview>
- Google. (n.d.-c). *Security policy overview | google cloud armor | google cloud documentation*. Google. <https://docs.cloud.google.com/armor/docs/security-policy-overview>
- Google. (n.d.-d). *Security policy overview | google cloud armor | google cloud documentation*. Google. <https://docs.cloud.google.com/armor/docs/security-policy-overview>